Traceability Matrices

Event Management System — generated 13 November 2026 from the same data as the SRS and Test Plan

List 1 — SRS requirement → test case (forward trace)

Test IDs: functional `FRnnn-UT/IT/ST_nn` (Test Plan §5.2), non-functional `NFT_nn` (§5.3), security `SEC_nn` (§5.1).

Functional requirements

Req	Title	SAD component	Module	Issue	Test cases	#	Result
FR-001a	Account creation	Authentication	app/api/auth/signup	#1	FR001-UT_01, FR001-UT_02, FR001-ST_01, FR001-ST_02	4	**Pass**
FR-001b	Email verification	Authentication	app/api/auth/verify, lib/tokens.ts	#2	FR001-IT_01, FR001-IT_02, FR001-ST_01	3	**Pass**
FR-002a	Login	Authentication	app/api/auth/login, lib/session.ts	#3	FR002-UT_01, FR002-UT_02, FR002-ST_01, FR003-ST_02	4	**Pass**
FR-002b	Password reset	Authentication	app/api/auth/forgot-password, reset-password	#4	FR002-IT_01, FR002-IT_02, FR002-ST_01, FR002-ST_02	4	**Pass**
FR-003a	Role-based access control	Authentication	lib/auth.ts	#5	FR003-UT_01, FR003-ST_01, FR004-ST_02	3	**Pass**
FR-003b	Profile update	Authentication	app/api/auth/me	#6	FR003-UT_02	1	**Pass**
FR-003c	Admin manages user accounts	UserAccounts	app/api/admin/users	#7	FR003-IT_01, FR003-IT_02, FR003-ST_02	3	**Pass**
FR-004a	Create event	EventManager	app/api/events	#8	FR004-UT_01, FR004-UT_02, FR004-IT_02, FR004-ST_01, FR004-ST_02	5	**Pass**
FR-004b	Edit event	EventManager	app/api/events/[id] (PUT)	#9	FR004-IT_01, FR004-IT_02, FR004-ST_01	3	**Pass**
FR-005a	Cancel or delete event	EventManager	app/api/events/[id] (PATCH, DELETE)	#10	FR005-UT_01, FR005-UT_02, FR005-ST_02, FR007-ST_02	4	**Pass**
FR-005b	Notify participants of change	NotificationService	lib/registration.ts, lib/emailTemplates.ts	#11	FR005-IT_01, FR005-IT_02, FR005-ST_01, FR005-ST_02	4	**Pass**

FR-006a	View events	EventCatalog	app/events, app/api/events (GET)	#12	FR006-ST_02	1	**Pass**
FR-006b	Search and filter events	EventCatalog	lib/eventFilters.ts	#13	FR006-UT_01, FR006-UT_02, FR006-IT_02, FR006-ST_01, FR006-ST_02	5	**Pass**
FR-006c	Admin manages categories	Categories	lib/categories.ts, app/api/admin/categories	#14	FR006-IT_01	1	**Pass**
FR-007	Register for event	Registration	app/api/events/[id]/register	#15	FR007-UT_01, FR007-UT_02, FR007-IT_01, FR007-IT_02, FR007-ST_01, FR007-ST_02	6	**Pass**
FR-008	Capacity check	CapacityCheck	lib/registration.ts	#16	FR007-IT_01, FR008-UT_01, FR008-UT_02, FR008-IT_01, FR008-IT_02, FR008-ST_01, FR008-ST_02	7	**Pass**
FR-009a	Waitlist with auto-promotion	Waitlist	lib/registration.ts	#17	FR008-ST_02, FR009-UT_01, FR009-IT_01, FR009-ST_01	4	**Pass**
FR-009b	Self-cancellation and notifications	Registration, NotificationService	lib/registration.ts, app/api/reminders	#18	FR009-UT_02, FR009-IT_02, FR009-ST_02	3	**Pass**
FR-010a	Counts, seat availability and export	Reports	lib/export.ts	#19	FR007-IT_02, FR010-UT_01, FR010-UT_02, FR010-IT_01, FR010-IT_02, FR010-ST_02	6	**Pass**
FR-010b	Admin platform statistics	Reports	lib/stats.ts, app/api/admin/stats	#20	FR010-ST_01	1	**Pass**

Non-functional requirements

Req	Category	Test cases	Per-test results	Overall
NFR-001	Performance	NFT_01, NFT_02	NFT_01 Pass; NFT_02 Fail	**Fail**
NFR-002	Scalability and concurrency	NFT_03, NFT_04	NFT_03 Pass; NFT_04 Pass	**Pass**
NFR-003	Security - data protection	NFT_05, SEC_01, SEC_06, SEC_12	NFT_05 Pass	**Pass**
NFR-004	Security - access control	NFT_06, SEC_03, SEC_04, SEC_05, SEC_09, SEC_10, SEC_11, SEC_13	NFT_06 Partial	**Partial**
NFR-005	Availability and recovery	NFT_07	NFT_07 Partial	**Partial**
NFR-006	Usability and accessibility	NFT_08, NFT_11	NFT_08 Partial; NFT_11 Fail	**Fail**

NFR-007	Maintainability	NFT_09, NFT_10	NFT_09 Pass; NFT_10 Fail	**Fail**

Coverage check

20 of 20 FRs and 7 of 7 NFRs have at least one test case. Every one of the 60 functional cases maps to at least one FR; no FR has fewer than 1 case (minimum 2: FR-006a, FR-009a/b share cases with siblings as shown).

List 2 — Security requirement → test case (SRSec → SR → SEC)

Req	SRSec §	Requirement	Objective / NFR	Test case(s)	Test results	Status in main
SR-001	2.1	Passwords shall be stored only as salted bcrypt/Argon2 hashes and never logged.	SO-1 / NFR-003	SEC_01	SEC_01 Pass	**Met**
SR-002	2.2	Session cookies shall be HttpOnly, SameSite and Secure (production), HMAC-signed, and shall expire after 30 minutes of inactivity.	SO-1, SO-2 / NFR-004	SEC_02, SEC_11	SEC_02 Pass; SEC_11 Fail	**Partial**
SR-003	2.3	The account shall lock after 5 consecutive failed login attempts.	SO-3 / NFR-004	SEC_03	SEC_03 Fail	**Not met in main**
SR-004	3.1, 3.2	RBAC and least privilege shall be enforced on the server for every request; no client-supplied role claim shall be trusted.	SO-2 / NFR-004	SEC_04, SEC_13	SEC_04 Pass; SEC_13 Fail	**Partial**
SR-005	3.3	Object references shall be authorized server-side (ownership checks) to prevent IDOR.	SO-2 / NFR-004	SEC_05	SEC_05 Pass	**Met**
SR-006	4.1	All client-server traffic shall use TLS 1.2 or higher.	SO-1 / NFR-003	SEC_06	SEC_06 Not run	**Met (hosting)**
SR-007	4.2	Sensitive data at rest shall be encrypted.	SO-1 / NFR-003	SEC_06	SEC_06 Not run	**Met (hosting)**
SR-008	5.1	All database access shall use parameterized queries / an ORM.	SO-2 / NFR-004	SEC_07	SEC_07 Pass	**Met**
SR-009	5.2	User-supplied input shall be validated and output encoded to prevent XSS.	SO-2 / NFR-004	SEC_08, SEC_15	SEC_08 Pass; SEC_15 Pass	**Met**
SR-010	5.3	State-changing requests shall be protected against CSRF.	SO-2 / NFR-004	SEC_09	SEC_09 Partial	**Partial**
SR-011	6.1, 6.2	Security events and administrative actions shall be recorded in a durable audit log (12 months) without secrets or plain-text passwords.	SO-3 / NFR-004, NFR-007	SEC_10	SEC_10 Fail	**Not met in main**
SR-012	2.1	Verification and reset tokens shall be random, single-use, time-limited and stored hashed; login errors shall not reveal whether an account exists.	SO-1 / NFR-003	SEC_12, SEC_14	SEC_12 Pass; SEC_14 Pass	**Met**

Security test cases

ID	SRSec §	Requirement(s)	Description	Result	Evidence
SEC_01	2.1	SR-001	Passwords are stored as bcrypt hashes, never plain text or in logs.	**Pass**	Live TC-4 (hash starts $2, differs from password); code review of signup/reset-password.
SEC_02	2.2	SR-002	Session cookie is HttpOnly, SameSite=Lax, Secure in production; HMAC verified in constant time; tampered or expired cookies rejected.	**Pass**	tests/session.test.ts (13 tests).

SEC_03	2.3	SR-003	Account locks after 5 consecutive failed logins.	**Fail**	Not in main. Uncommitted local work exists (login route + schema) but has no tests and breaks `tsc` (Next route file exports a constant).
SEC_04	3.1/3.2	SR-004	A role without permission calling an endpoint directly gets 403 and no data.	**Pass**	api-routes (export 403), admin-categories (non-admins), admin-stats (RBAC), live TC-16/TC-21, fr003a TC-1.
SEC_05	3.3	SR-005	Organizer A cannot edit, cancel or export Organizer B's event (IDOR).	**Pass**	event-edit (403 non-owner), event-notifications (unauthorized cancel), api-routes (export / registrations 403 other organizer).
SEC_06	4.1/4.2	SR-006, SR-007	All traffic over TLS 1.2+; data encrypted at rest.	**Not run**	Provided by the hosting platform; no TLS scan or storage audit was possible locally. Secure cookie attribute in production is tested (SEC_02).
SEC_07	5.1	SR-008	SQL-injection payloads in search/filter/event fields have no effect.	**Pass**	event-search (special characters plain text; LIKE wildcards escaped); no raw SQL in lib/ or app/api/.
SEC_08	5.2	SR-009	Script payloads are escaped in notification email and page output.	**Pass**	event-notifications ('escape HTML'), email-templates tests.
SEC_09	5.3	SR-010	A cross-site request cannot perform a state-changing action with the victim's session.	**Partial**	SameSite=Lax only; no anti-CSRF token.
SEC_10	6.1/6.2	SR-011	Security events and admin actions are written to a durable audit log without secrets.	**Fail**	Not in main; only console.error. AuditLog implementation exists in uncommitted local work, untested.
SEC_11	2.2	SR-002	A session idle for 30 minutes is rejected.	**Fail**	lib/session.ts uses a fixed 7-day absolute TTL; no inactivity timeout (NFR-004 not met).
SEC_12	2.1	SR-012	Verification and reset tokens are single-use, expiring and stored hashed.	**Pass**	Live TC-8..TC-10; fr002b TC-5..TC-7; tokens stored as sha256 hash.
SEC_13	3.1	SR-004	An unauthenticated caller cannot act as Organizer or Participant by sending an x-user-role header or event_session_role cookie.	**Fail**	lib/auth.ts getAuthUserFromRequest falls back to the demo role claim when there is no session (fr003a TC-4 confirms an Organizer action succeeds). requireAdmin is not affected (real session only).
SEC_14	2.1	SR-012	Login and forgot-password do not reveal whether an email is registered.	**Pass**	fr002a TC-3 (same error), fr002b TC-2 (same message).
SEC_15	5.2	SR-009	CSV export neutralizes spreadsheet formula-injection payloads.	**Pass**	tests/registration.test.ts (formula-injection case).
SEC_16	3.1	SR-004	A suspended user's still-valid session stops working on the next request.	**Pass**	Live TC-17; fr003a TC-3.

> Failing or partial security items (SEC_03, SEC_09, SEC_10, SEC_11, SEC_13) are documented deviations D3, D4, D5, D8 in SAD 4.6. SEC_13 (demo role header accepted without a session) was discovered during this review.